

MAPEO NORMATIVO DETALLADO

Correspondencia entre Preguntas de la Encuesta DREAD y Requisitos Normativos

Kit de Encuesta DREAD · Edición 2025–2026

"La regulación sin métricas es teatro. Las métricas sin regulación son experimentos. Esta tabla es el punto donde ambas se dan la mano."

LEYENDA DE MARCOS NORMATIVOS

Código	Marco normativo / Estándar
NIS2	Directiva (UE) 2022/2555 + Anteproyecto LCGC España (enero 2025)
ENS	Real Decreto 311/2022 — Esquema Nacional de Seguridad
DORA	Reglamento (UE) 2022/2554 — Digital Operational Resilience Act
GDPR	Reglamento (UE) 2016/679 + LOPDGDD (LO 3/2018)
NIS2-ES	Anteproyecto Ley de Coordinación y Gobernanza de la Ciberseguridad (España, enero 2025)
MAGERIT	Metodología de Análisis y Gestión de Riesgos de los SSII (CCN-CERT)
INCIBE-IMC	Indicadores de Madurez en Ciberseguridad — Metodología QM (INCIBE)
ENISA-ETL	ENISA Threat Landscape Methodology (agosto 2025)
ISO27001	ISO/IEC 27001:2022 — Sistemas de Gestión de Seguridad de la Información
NIST-CSF	NIST Cybersecurity Framework v2.0 (2024)
IEC62443	IEC 62443 — Ciberseguridad industrial (OT/ICS)
CRA	Cyber Resilience Act (UE, 2024)

TABLA MAESTRA DE MAPEO NORMATIVO

Pregunta	Dimensión DREAD	ENS	NIS2 / NIS2-ES	DORA	GDR	ISO27001	NIST-CSF	MAGERIT	INCIBE-IMC	IEC62443	CRA	Observaciones
P0.5 — Identificación como operador esencial/importante	—	✓ Art.28	✓ Art.3 + NIS2-ES Arts. 4-7	—	—	—	—	—	✓	—	—	NIS2 Art.3 define entidades esenciales e importantes; NIS2-ES amplía con sectores adicionales para España
P1.2 — Frameworks de evaluación utilizados	Todos	✓ Anexo I	✓ Art.21.2	✓ Arts. 5-8	—	✓ A.6.1.2	✓ GV.RM	✓ Fase III	✓ GQM	—	—	NIS2 Art.21.2 exige gestión de riesgos con metodología formal

P2.1 — Evaluación del Daño potencial	D — Daño	✓ Cat. ALTA /ME DIA/ BÁSICA	✓ Art.2 1.2.a	✓ Art.6. 1	✓ Art.3 3	✓ A.8.8	✓ ID.R A	✓ Crite rio C/I/ D	✓ KRI- 01	—	—	ENS clasifica sistemas en categorías de seguridad por impacto en C/I/D
P2.2 — Sub-indicadores de Daño considerados	D — Daño	✓ Cat. ALTA	✓ Art.2 1.2.b	✓ Art.6. 2-3	✓ Arts. 33-34	✓ A.5.3 0, A.8.8	✓ ID.R A-01	✓ Valoración activos	✓ KRI- 01, KRI- 02	—	—	Impacto en vidas humanas — IEC6 2443 para entornos OT
P2.3 — Daño en últimos incidentes	D — Daño	✓	✓ Art.2 3	✓ Art.1 9	✓ Art.3 3.3	✓ A.5.2 4	✓ RS.A N	✓	✓ KPI- 03	—	—	NIS2 Art.2 3: notificación de incidentes significativos en < 24h / 72h

P2.4 — Vinculación Daño con notificación regulatoria	D — Daño	✓ Art.40	✓ Arts.23-24	✓ Arts.19-20	✓ Arts.33-34	✓ A.5.26	✓ RS.CO	—	✓ KPI-04	—	—	DOR A Arts.19-20: clasificación de incidentes y notificación al regulador financiero
P2.5 — Cuantificación financiera del daño	D — Daño	—	✓ Art.21.2	✓ Arts.6-8	—	✓ A.6.1.2	✓ GV.RM-06	✓	✓ KRI-03	—	—	DOR A exige cuantificación del impacto financiero para entidades financieras
P3.1 — Evaluación de Reproducibilidad	R — Reproducibilidad	✓	✓ Art.21.2.e	—	—	✓ A.8.8	✓ ID.RA-01	✓ Amenaza P.A	✓ KRI-05	—	—	ENS exige análisis de amenazas con probabilidad de ocurrencia

P3.2 — Seguimiento de exploits públicos	R — Reproducción	✓	✓ Art.2 1.2.e	—	—	✓ A.8.8	✓ ID.R A-01	✓	✓ KPI- 07	—	✓ Art.1 3	CRA Art.1 3: oblig ación de monit orizar vulnera bilib dades en prod uctos con elem entos digi tales
P3.3 — Uso del EPSS	R + E	—	✓ Art.2 1	—	—	—	✓ ID.R A	—	✓	—	—	EPSS propor ciona probabi lidad objet iva que alimen ta R y E de DRE AD

P3.4 — MTT R de vuln erabi lidad es crític as	R — Repr oduci bilid ad	✓ Medi da 5	✓ Art.2 1.2.e	✓ Art.5. 2	—	✓ A.12. 6.1	✓ RC.R P	✓	✓ KPI- 08	✓	✓ Art.1 3	DOR A Art.5. 2 exige gesti ón del riesg o TIC con plazo s de reme diaci ón defin idos
P3.5 — Repr oduci bilid ad en OT/I CS/Io T	R — Repr oduci bilid ad	—	✓ Anex o I secto res	—	—	—	✓	—	—	✓ Full	✓	IEC 6244 3-3- 3: evalu ación de amen azas en siste mas de contr ol indu strial

P4.1 — Evaluación de la Explo- tabili- dad	E — Expl otabi- lidad	✓	✓ Art.2 1.2	✓ Art.6	—	✓ A.8.8	✓ ID.R A	✓ P.A (pro- babil- idad)	✓ KRI- 06	—	—	ENS: análi- sis de amen- azas inclu- ye prob- abili- dad de explo- tació- n
P4.2 — Im- pacto de IA gene- rativa en Explo- tabili- dad	E — Expl otabi- lidad	—	✓ Art.2 1.2	—	—	✓ A.8.2 8	✓ ID.R A-05	—	✓	—	—	ENIS A ETL 2025 repor- ta +75 % en ataq- ues auto- mati- zados con IA; NIS2 exige actua- lizar análi- sis de amen- azas

P4.3 — Explo tabili dad en ataq ues sobr e IA/LL Ms	E — Expl otabi lidad	—	✓ Art.2 1	—	✓ Art.2 5 (priv acy by desig n)	✓ A.8.2 8	✓ ID.R A-05	—	—	—	—	GDP R Art.2 5: priva cy by desig n aplic a a siste mas de IA que proce san datos perso nales
P4.4 — Perfil es de ataca nte	E — Expl otabi lidad	✓	✓ Art.2 1.2	—	—	✓ A.6.1. 2	✓ ID.R A-03	✓ Agen tes de amen aza	✓	—	—	MAG ERIT : ident ificac ión de agent es de amen aza como parte del análi sis
P4.5 — Cont roles para redu cir Explo tabili dad	E — Expl otabi lidad	✓ Meas ures ENS	✓ Art.2 1.2	✓ Art.9	—	✓ Anne x A	✓ PR.A A, PR.A C	✓ Salva guard as	✓ KPI- 10	✓	✓	ENS Anex o II: medi das de segur idad clasif icada s por dime nsión

P5.1 — Cuan tifica ción de usua rios afect ados	A — Usua rios Afect ados	✓ Categ oriza ción	✓ Art.2 3.3 (inci dente s signif icativ os)	✓ Art.1 9.3	✓ Art.3 3 (pers onas afect adas)	✓ A.5.3 0	✓ ID.R A	✓ Activ os: Usua rios	✓ KRI- 07	—	—	NIS2 Art.2 3.3: "gran mag nitud " → afect a a muc hos usua rios o secto res esenc iales
P5.2 — Umb rales de usua rios para prot ocolo s	A — Usua rios Afect ados	✓	✓ Arts. 23-24	✓ Arts.1 9-20	✓ Arts. 33-34	✓ A.5.2 4	✓ RS.C O	—	✓ KPI- 05	—	—	GDP R: notifi cació n a AEP D si > 0 perso nas física s afect adas con alto riesg o; NIS2: umbr ales propi os

P5.3 — Grupos con protección diferenciada	A — Usuarios Afectados	—	—	—	✓ Arts. 9-10 (datos especiales)	✓ A.5.3 4	—	—	—	—	—	GDP R Arts. 9-10: categorías especiales de datos y personas vulnerables requieren protección reforzada
P5.4 — Escala territorial / sectorial	A — Usuarios Afectados	—	✓ Art.2 3 (impacto transfronterizo)	✓ Art.1 9	—	—	✓ GV.S C	—	✓	—	—	NIS2 Art.2 3: notificación ENISA si impacto transfronterizo; NIS2- ES: CNCS coordinación nacional

P5.5 — Inventario de activos y mapa de afectación	A — Usuarios Afectados	✓ Medida 2 (inventario)	✓ Art.2 1.2.f	✓ Art.8	—	✓ A.8.1	✓ ID.AM	✓ Inventario activos	✓ KPI-01	✓	✓	ENS Medida 2: gestión de activos; NIS2 Art.2 1.2.f: gestión de activos TIC
P6.1 — Enfoque sobre Descubribilidad	D — Descubribilidad	✓	✓ Art.2 1.2.e	—	—	✓ A.8.8	✓ ID.RA	✓ Vulnerabilidades	✓ KRI-08	—	—	ENS prohíbe implícitamente la seguridad por oscuridad como medida única de protección

P6.2 — Vigilancia digital activa	D — Descubribilidad	✓	✓ Art.2 1.2.h	—	—	✓ A.8.1 6	✓ DE.C M	—	✓ KPI- 09	—	—	NIS2 Art.2 1.2.h: monitoreo y análisis de amenazas; NIST- CSF: Detect. Continuo us Monitoring
P6.3 — Red team y pentest	D — Descubribilidad	✓	✓ Art.2 1.2	✓ Art.2 6 (TLP T)	—	✓ A.8.8	✓ ID.R A-05	✓	✓	—	—	DORA Art.2 6: Threat-Led Penetration Testing (TLP T) obligatorio para entidades financieras significativas

P6.4 — Attack Surface Management	D — Descubribilidad	✓	✓ Art.2 1.2.e	✓ Art.8	—	✓ A.8.8	✓ ID.A M, DE.C M	✓	✓ KPI- 11	—	✓	CRA: obligación de gestionar la superficie de ataque en productos con elementos digitales
P7.1 — Nivel de automatización del scoring	Todos	✓	✓ Art.2 1	✓ Art.5	—	✓ A.8.1 6	✓ DE.C M, R.S.A N	—	✓ KPI- 12	—	—	NIS2 Art.2 1: medidas de gestión de riesgos deben ser proporcionadas al estado del arte

P7.2 — Herramientas de scoring	Todos	✓	✓	✓	—	✓	✓	✓ PILAR	✓	—	—	ENS recomienda herramienta PILAR/EAR; NIS2 exige herramientas adecuadas al estado del arte
P7.3 — DREAD con Machine Learning	Todos	—	✓ Art.21 (estado del arte)	—	✓ Art.25 (IA que trata datos)	—	✓	—	—	—	—	NIS2 Art.21: "estado del arte" incluye soluciones ML para scoring de amenazas

P7.4 — Frecuencia de revisión	Todos	✓	✓ Art.2 1.2.e	✓ Art.5. 5	—	✓ A.6.1, A.8.8	✓ ID.R A	✓	✓ KPI- 13	—	—	DOR A Art.5. 5: revisión periódica del marco de gestión de riesgos TIC
P7.5 — Consistencia inter-analista	Todos	—	✓ Art.2 1	—	—	✓ A.6.1. 2	✓ GV.R M	✓	✓	—	—	ISO2 7001: el SGSI debe garantizar consistencia en la evaluación de riesgos

P8.2 — Alineación con ENS	Todo s	✓ Full	—	—	—	✓	—	✓ Full	✓	—	—	ENS es de aplicación obligatori a a todas las AAPP y sus proveedor es de servi cios TIC
P8.3 — Alineación con NIS2 / LCGC	Todo s	—	✓ Full	—	—	✓	—	—	✓	—	—	LCGC Espa ña (ener o 2025): crea CNCS , defin e entid ades, plazo s y oblig acion es

P8.4 — Alineación con DORA	Todos	—	—	✓ Full	—	✓	✓	—	✓	—	—	DORA de aplicación desde enero 2025 para entidades financieras en la UE
P8.5 — KPIs/ KRIs al Consejo	Todos	✓	✓ Art.20 (gobernanza)	✓ Art.5	—	✓ A.5.35	✓ GV.RR	—	✓ Full	—	—	NIS2 Art.20: el órgano de dirección aprueba y supervisa las medidas de gestión de riesgos
P9.1 — Escalación nacional en evaluación de riesgos	A — Usuarios Afectados	—	✓ Art.21 + NIS2-ES	—	—	—	✓ GV.SC	—	✓	—	—	NIS2-ES: el CNCS coordinará el análisis de riesgos a nivel nacional

P9.2 — Coor dinac ión con orga nism os nacio nales	Todo s	✓	✓ Arts. 26-27	—	—	—	✓ RS.C O	—	✓	—	—	NIS2 Arts. 26- 27: coop eraci ón con CSIR Ts y Auto ridad es Com peten tes
P9.3 — BCP/ DRP ante ciber incid ente s	D + A	✓	✓ Art.2 1.2.c	✓ Art.11	—	✓ A.5.3 O	✓ RC.R P	✓	✓ KPI- 15	—	—	DOR A Art.11 : plane s de conti nuid ad del nego cio espec ílicos para incid entes TIC

P10.1 — Cultura de ciberseguridad	Todos	✓	✓ Art.2 1.2.g (formación)	✓ Art.1 3	—	✓ A.6.3	✓ PR.A T	—	✓	—	—	NIS2 Art.2 1.2.g: programas de formación y concienciación como medida obligatoria
P10.2 — Formación en metodologías	Todos	✓	✓ Art.2 1.2.g	✓ Art.1 3	—	✓ A.6.3	✓ PR.A T	—	✓	✓	—	DORA Art.1 3: formación específica en resiliencia operacional digital

P10.3 — Presupuesto de ciberseguridad	Todos	—	✓ Art.21 (proporcionalidad)	✓ Arts.5-6	—	✓ A.5.35	✓ GV.RM	—	✓	—	—	NIS2 Art.21: las medidas deben ser proporcionales al riesgo y a los recursos de la entidad
---------------------------------------	-------	---	-----------------------------------	---------------	---	-------------	------------	---	---	---	---	---

TABLA DE ARTÍCULOS NORMATIVOS CLAVE

NIS2 — Artículos con mayor incidencia en la encuesta

Artículo NIS2	Contenido	Preguntas relacionadas
Art. 3	Identificación de entidades esenciales e importantes	P0.5
Art. 20	Gobernanza: responsabilidad del órgano de dirección	P8.5, P10.1
Art. 21	Medidas de gestión de riesgos de ciberseguridad	P1.2, P2.1, P4.1, P7.1, P7.4
Art. 21.2.a	Políticas de seguridad y análisis de riesgos	P2.1, P3.1, P4.1
Art. 21.2.b	Gestión de incidentes	P2.3, P2.4
Art. 21.2.c	Continuidad del negocio	P9.3
Art. 21.2.e	Seguridad en la cadena de suministro	P3.2, P6.4
Art. 21.2.f	Gestión de activos y seguridad en la adquisición	P5.5
Art. 21.2.g	Formación y concienciación	P10.1, P10.2
Art. 21.2.h	Monitorización continua y análisis de ciberseguridad	P6.2, P7.1
Art. 23	Notificación de incidentes (alerta 24h, notificación 72h, informe final 1 mes)	P2.4, P5.2
Art. 26-27	Cooperación con CSIRTs y Autoridades Competentes	P9.2

ENS — Medidas con mayor incidencia en la encuesta

Medida ENS	Categoría	Preguntas relacionadas
Marco Organizativo — Política de Seguridad	Todas	P1.2, P8.2
Marco Operacional — Planificación (análisis de riesgos)	Gestión	P2.1, P3.1, P4.1, P5.1
Medida 2 — Gestión de activos	Operacional	P5.5, P6.4
Medida 5 — Gestión de vulnerabilidades	Operacional	P3.2, P3.4
Medida técnica — Monitorización	Técnica	P6.2, P7.1
Categoría ALTA/MEDIA/BÁSICA	Clasificación	P2.1, P0.4

DORA — Artículos clave

Artículo DORA	Contenido	Preguntas relacionadas
Art. 5	Marco de gestión del riesgo TIC	P7.4, P8.4
Art. 6	Política de gestión del riesgo TIC	P2.1, P4.1
Art. 8	Gestión de activos TIC	P5.5, P6.4
Art. 9	Protección y prevención	P4.5
Art. 11	Continuidad del negocio y recuperación	P9.3
Art. 13	Aprendizaje y evolución / Formación	P10.2
Art. 19	Clasificación de incidentes	P2.3, P5.2
Art. 20	Notificación de incidentes graves	P2.4
Art. 26	TLPT (Threat-Led Penetration Testing)	P6.3

NOTAS METODOLÓGICAS SOBRE EL MAPEO

1.

Principio de proporcionalidad normativa: NIS2 y ENS aplican el principio de proporcionalidad: las obligaciones son más exigentes para entidades esenciales (categoría ALTA en ENS) que para entidades importantes o básicas. El mapeo refleja los requisitos en su nivel más exigente; cada organización debe calibrar según su categorización real.

2.

Solapamiento normativo: Muchas preguntas mapeadas a NIS2 también mapean a ISO 27001 y NIST-CSF, ya que NIS2 no prescribe controles específicos sino objetivos de seguridad, y la forma de alcanzarlos puede ser mediante ISO 27001 u otros marcos equivalentes reconocidos por ENISA.

3.

DORA como *lex specialis*: Para entidades del sector financiero, DORA prevalece sobre NIS2 como marco sectorial específico en materia de resiliencia digital. El mapeo doble (NIS2 + DORA) en preguntas de gestión de incidentes y continuidad refleja esta relación.

4.

CRA (Cyber Resilience Act): Plenamente aplicable desde diciembre 2027, pero con obligaciones de diseño seguro y gestión de vulnerabilidades que ya afectan a fabricantes de productos digitales desde 2025 (período transitorio). El mapeo anticipatorio permite a los fabricantes posicionarse con antelación.

5.

IEC 62443: Solo aplica a organizaciones con entornos OT/ICS. El mapeo se ha realizado para la versión 62443-3-3 (requisitos de seguridad del sistema) que es la más relevante para la evaluación de reproducibilidad y explotabilidad en sistemas industriales.

Principio de proporcionalidad normativa: NIS2 y ENS aplican el principio de proporcionalidad: las obligaciones son más exigentes para entidades esenciales (categoría ALTA en ENS) que para entidades importantes o básicas. El mapeo refleja los requisitos en su nivel más exigente; cada organización debe calibrar según su categorización real.

Solapamiento normativo: Muchas preguntas mapeadas a NIS2 también mapean a ISO 27001 y NIST-CSF, ya que NIS2 no prescribe controles específicos sino objetivos de seguridad, y la forma de alcanzarlos puede ser mediante ISO 27001 u otros marcos equivalentes reconocidos por ENISA.

DORA como *lex specialis*: Para entidades del sector financiero, DORA prevalece sobre NIS2 como marco sectorial específico en materia de resiliencia digital. El mapeo doble (NIS2 + DORA) en preguntas de gestión de incidentes y continuidad refleja esta relación.

CRA (Cyber Resilience Act): Plenamente aplicable desde diciembre 2027, pero con obligaciones de diseño seguro y gestión de vulnerabilidades que ya afectan a fabricantes de productos digitales desde 2025 (período transitorio). El mapeo anticipatorio permite a los fabricantes posicionarse con antelación.

IEC 62443: Solo aplica a organizaciones con entornos OT/ICS. El mapeo se ha realizado para la versión 62443-3-3 (requisitos de seguridad del sistema) que es la más relevante para la evaluación de reproducibilidad y explotabilidad en sistemas industriales.

Kit de Encuesta DREAD · Mapeo Normativo v1.0 · Abril 2026

Basado en: NIS2 (2022/2555), ENS RD 311/2022, DORA (2022/2554), GDPR (2016/679), ISO/IEC 27001:2022, NIST CSF v2.0, IEC 62443, CRA (UE 2024), INCIBE-IMC, MAGERIT v3